

Reporte Ejecutivo

Gestión de Riesgos Tecnológicos y Seguridad de la Información

Fecha: 9 de Septiembre de 2026

Elaborado por: Emilia Ortiz (Analista de Seguridad / Licenciatura en Sistemas de Información)

Destinatario: Directorio de la Clínica

1. Resumen Ejecutivo

En respuesta a los hallazgos de la reciente auditoría externa, y considerando el contexto operativo crítico de nuestra clínica (volumen de 800 pacientes diarios, 120 colaboradores y dependencia absoluta de las Historias Clínicas Digitales), se ha llevado a cabo una evaluación formal de riesgos utilizando la plataforma **SimpleRisk**.

El objetivo principal ha sido identificar, cuantificar y planificar el tratamiento de las amenazas tecnológicas que podrían afectar la confidencialidad, integridad y disponibilidad de la información médica. Se han evaluado los activos críticos, resultando en un mapa de riesgos que destaca la exposición frente a ataques de ransomware y fugas de datos internos, para los cuales ya se han diseñado planes de mitigación concretos.

2. Top 5 Riesgos por Nivel

A continuación se detallan los 5 riesgos de mayor impacto evaluados en el sistema, ordenados por su criticidad (basada en la matriz de Probabilidad x Impacto):

ID	Amenaza / Evento	Activo Afectado	Categoría	Nivel (Score)
RSK-1001	Infección por Ransomware en HCD	Servidores HCD	Disponibilidad	Crítico (20)
RSK-1002	Fuga de datos por WhatsApp	Datos de Pacientes	Confidencialidad	Crítico (20)
RSK-1003	Caída de validación Obras Sociales	Enlace WAN	Disponibilidad	Alto (16)
RSK-1004	Exfiltración por terminales desatendidas	Terminales HCD	Confidencialidad	Alto (16)
RSK-1006	Alteración no autorizada de registros	Sistema HIS	Integridad	Medio (12)

3. Estado de los Planes de Acción

Se han documentado formalmente las estrategias de mitigación para los tres riesgos más críticos de la organización, los cuales se encuentran en estado de planificación a la espera de aprobación de presupuesto.

Plan 1: Mitigación contra Ransomware en Servidores HCD (RSK-1001)

Estrategia:	Implementar un sistema EDR (Endpoint Detection and Response) en todos los servidores y realizar capacitación obligatoria anti-phishing al personal.
Estado:	Planificado (Planned)
Responsable:	Administrador General
Vencimiento:	15/12/2026

Plan 2: Prevención de Fuga de Datos en Mensajería (RSK-1002)

Estrategia:	Contratar y desplegar una plataforma de mensajería corporativa cifrada exclusiva para uso médico, integrándola con las políticas del hospital para reemplazar el uso de WhatsApp.
Estado:	Planificado (Planned)
Responsable:	Luisa Fonsi (Analista de Riesgos)
Vencimiento:	30/11/2026

Plan 3: Alta Disponibilidad para Obras Sociales (RSK-1003)

Estrategia:	Instalar un enlace de internet de respaldo (Backup LTE/5G) configurado en alta disponibilidad (Failover automático) en el router principal de la clínica.
Estado:	Planificado (Planned)
Responsable:	Oscar Lopez (Auditor)
Vencimiento:	15/10/2026

4. Recomendaciones Prioritarias

Para asegurar la viabilidad de los planes propuestos y mejorar la postura de seguridad institucional, se recomienda al Directorio:

- **Aprobación Presupuestaria Inmediata:** Liberar los fondos para los Planes 1 y 2, dado que un ataque exitoso de ransomware o una filtración de datos de pacientes (incumplimiento de la Ley 25.326) tendrían costos reputacionales y operativos inasumibles para la clínica.

- **Actualización de Políticas Internas:** Elaborar un documento formal, firmado por todo el personal médico y administrativo, prohibiendo el uso de plataformas no corporativas (ej. WhatsApp) para la transmisión de estudios e Historias Clínicas.
- **Implementación de Bloqueo Automático:** Configurar las sesiones de las terminales desatendidas (guardias y consultorios) para que se bloqueen automáticamente tras 2 minutos de inactividad, mitigando el RSK-1004 a coste cero.
- **Monitoreo Continuo:** Establecer una reunión de revisión trimestral utilizando la plataforma SimpleRisk para auditar el avance de los planes de mitigación y detectar nuevas amenazas.